Lecture 1

Introduction to Information Security

بسم الله الرحمن الرحيم

Course Information

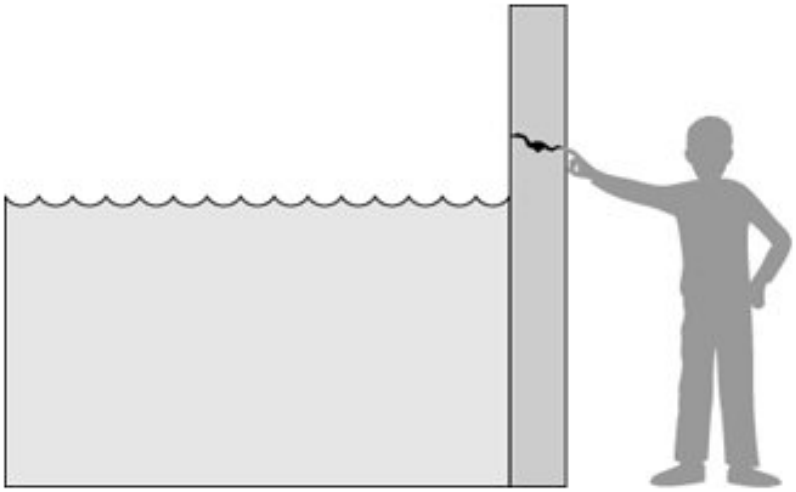
- Reference Books:
  - Cryptography and Network Security (Stallings)
  - Cryptography and Network Security (Ferouzan)
  - Corporate Computer and Network Security (Panko)
  - Security in Computing (Charles Pfleeger)
- Google/Xplore/Search the internet
- Study research papers

Grading Criteria

- Semester Work 50%
  - Quizzes 10%
  - Assignment 10%
  - Presentation 10%
  - Mid Term 20%
- Final Term 50%

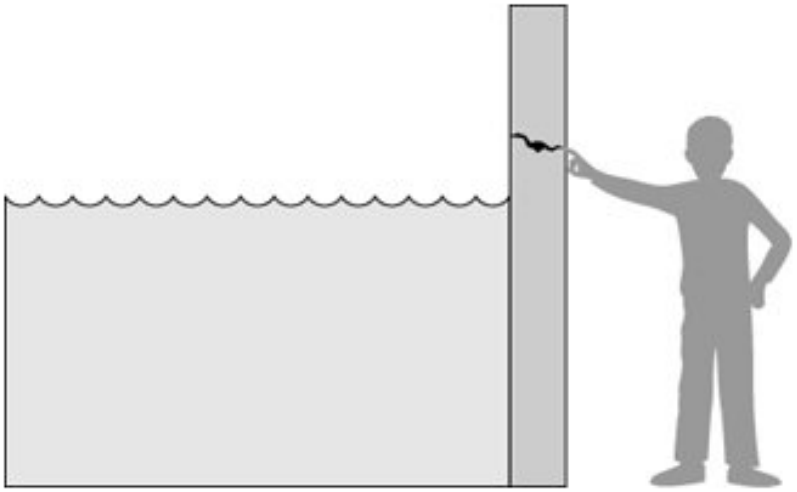
What is Security?

- V**ulnerability** is a weakness in the security system.
- T**hreat** to a computing system is a set of circumstances that has the potential to cause loss or harm.
- **Control** as a protective measure. That is, a control is an action, device, procedure, or technique that removes or reduces a vulnerability.

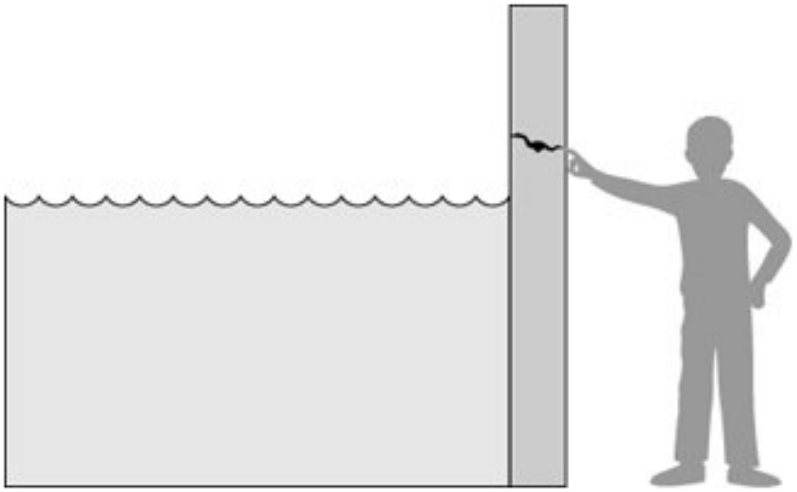


The water to the left of the wall is a ***threat*** to the man on the right of the wall: The water could rise, overflowing onto the man, or it could stay beneath the height of the wall, causing the wall to collapse.

So the threat of harm is the potential for the man to get wet, get hurt, or be drowned. For now, the wall is intact, so the threat to the man is unrealized

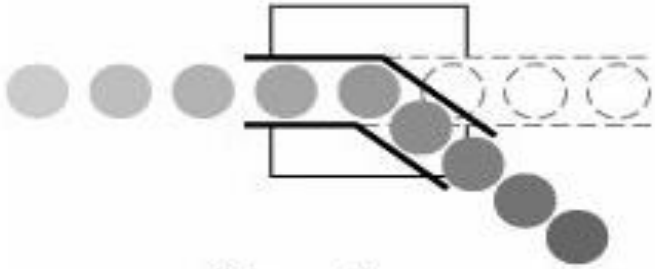


a small crack in the wall: a ***vulnerability*** that threatens the man's security. If the water rises to or beyond the level of the crack, it will exploit the vulnerability and harm the man.

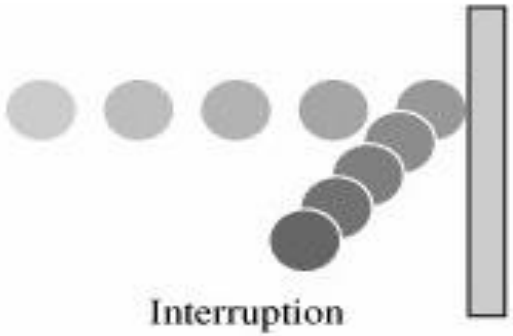


The man is placing his finger in the hole, ***controlling*** the threat of water leaks until he finds a more permanent solution to the problem.

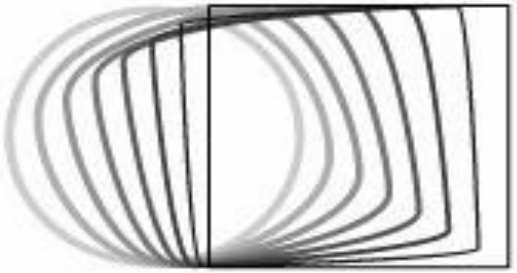
System Security Threats.



Interception



Interruption



Modification

Fabrication

Interception

- An **interception** means that some unauthorized party has gained access to an asset.
- The outside party can be a person, a program, or a computing system.
- **Key Characteristics**
  - Information is **read or copied**
  - No modification to data
  - Often difficult to detect
- **Examples**
  - Eavesdropping on network traffic
  - Wiretapping
  - Man-in-the-middle (passive mode)

Interruption

- **Interruption** occurs when a system resource, service, or data becomes **unavailable or unusable** to authorized users.
- **Key Characteristics**
  - Service is **stopped or denied**
  - Legitimate users cannot access resources
  - Data may remain intact but inaccessible
- **Examples**
  - Denial of Service (DoS / DDoS) attacks
  - Server crash due to attack

Modification

- If an unauthorized party not only accesses but tampers with an asset, the threat is a **modification**.
- Example, someone might change the values in a database, alter a program so that it performs an additional computation, or modify data being transmitted electronically.

Fabrication

- An attack in which an unauthorized entity creates and inserts false or fake data, messages, or transactions into a system.
- Example, the intruder may insert fake transactions to a network communication system or add records to an existing database.
- Sometimes these additions can be detected as forgeries, but if skillfully done, they are virtually indistinguishable from the real thing.

MOM

- A malicious attacker must have three things:
  - *method:* the skills, knowledge, tools, and other things with which to be able to pull off the attack
  - *opportunity:* the time and access to accomplish the attack
  - *motive:* a reason to want to perform this attack against this system
- Deny any of those three things and the attack will not occur.
- However, it is not easy to cut these off.

Security Goals

- The important security goals are “CIA”
  - Confidentiality
  - Integrity
  - Availability

Confidentiality

- Confidentiality ensures that computer-related assets are accessed only by authorized parties.
- That is, only those who should have access to something will actually get that access.
- Confidentiality is sometimes called **secrecy** or **privacy**

Integrity

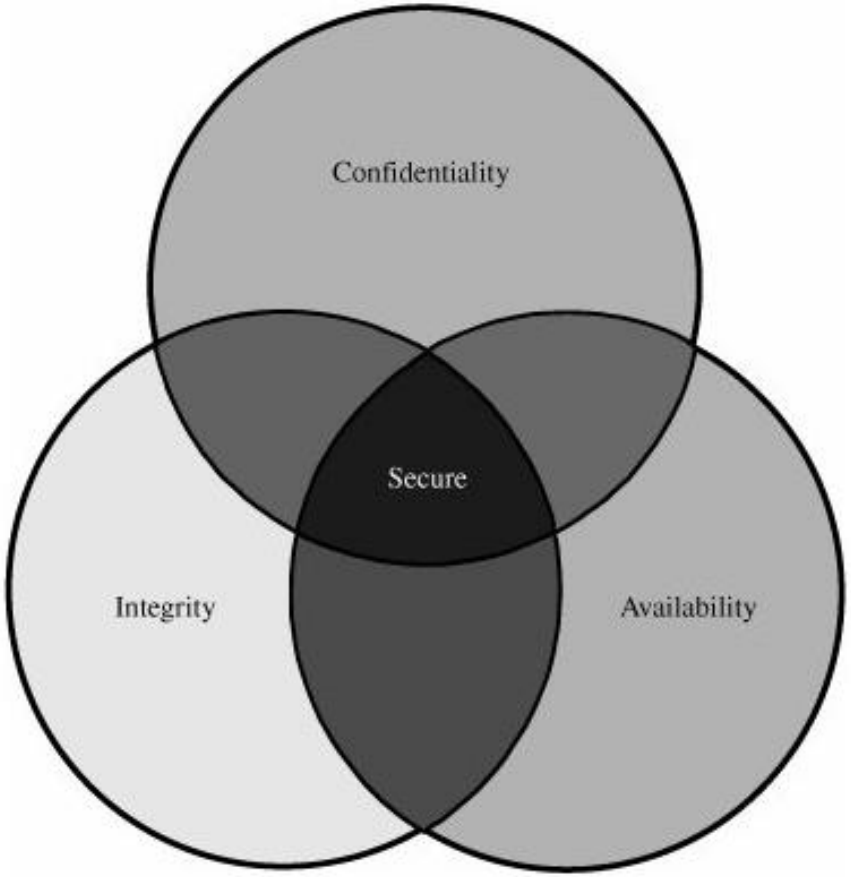
- Integrity means that assets can be modified only by authorized parties or only in authorized ways. In this context, modification includes writing, changing, changing status, deleting, and creating

Availability

- Availability means that assets are accessible to authorized parties at appropriate times.
- In other words, if some person or system has legitimate access to a particular set of objects, that access should not be prevented.
- Availability is sometimes known by its opposite, denial of service

CIA = Secure

Relationship Between Confidentiality, Integrity, and Availability.



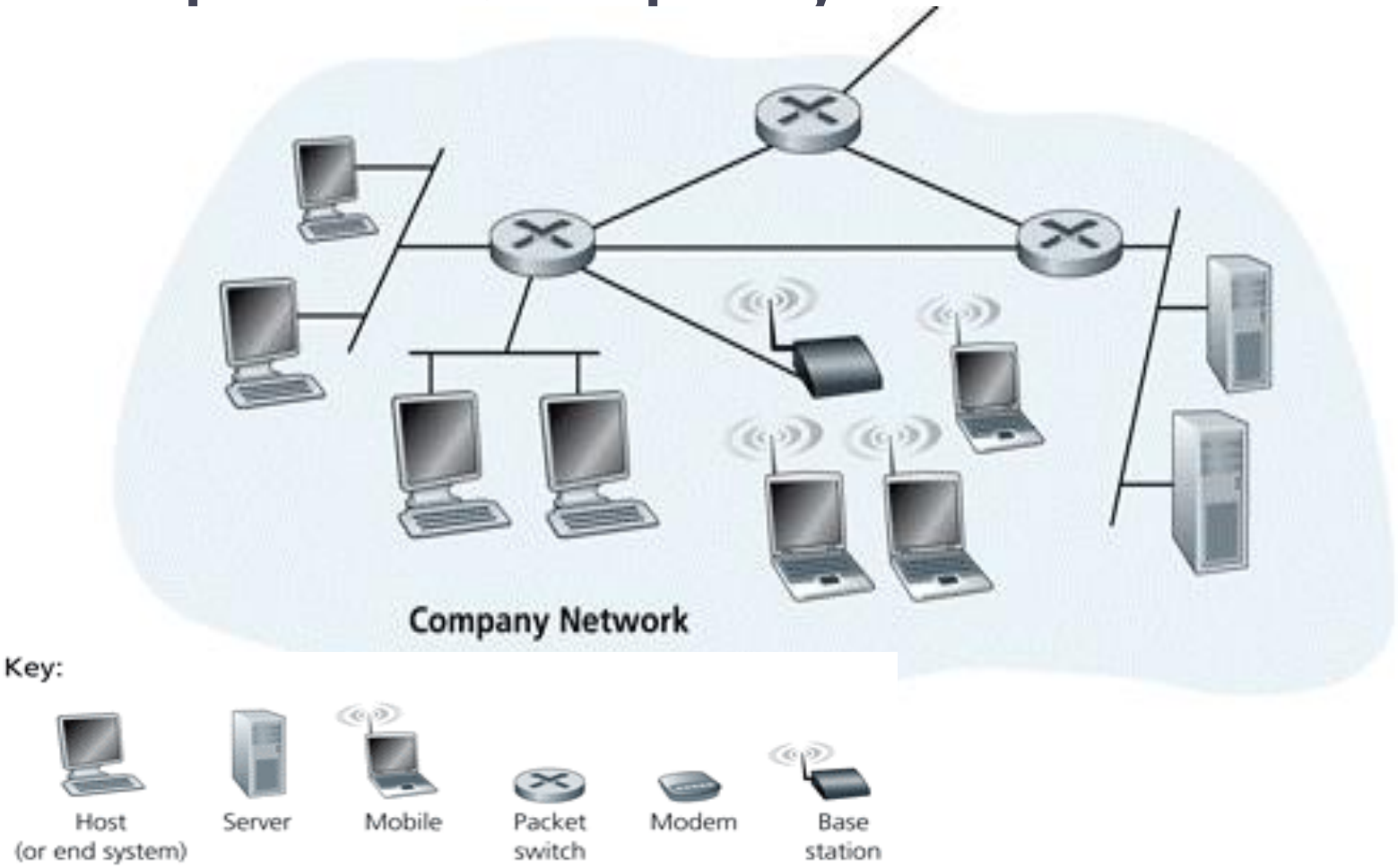
Introduction to Networks

- A network is not just a bunch of computers with wires running between them! But it is a system that provides its users with unique capabilities, above and beyond what individual machines can do!
- Motivation
  - Connectivity and Communication
  - Data Sharing
  - Hardware Sharing
  - Data Security and Management
  - Performance Enhancement and Balancing
  - Entertainment

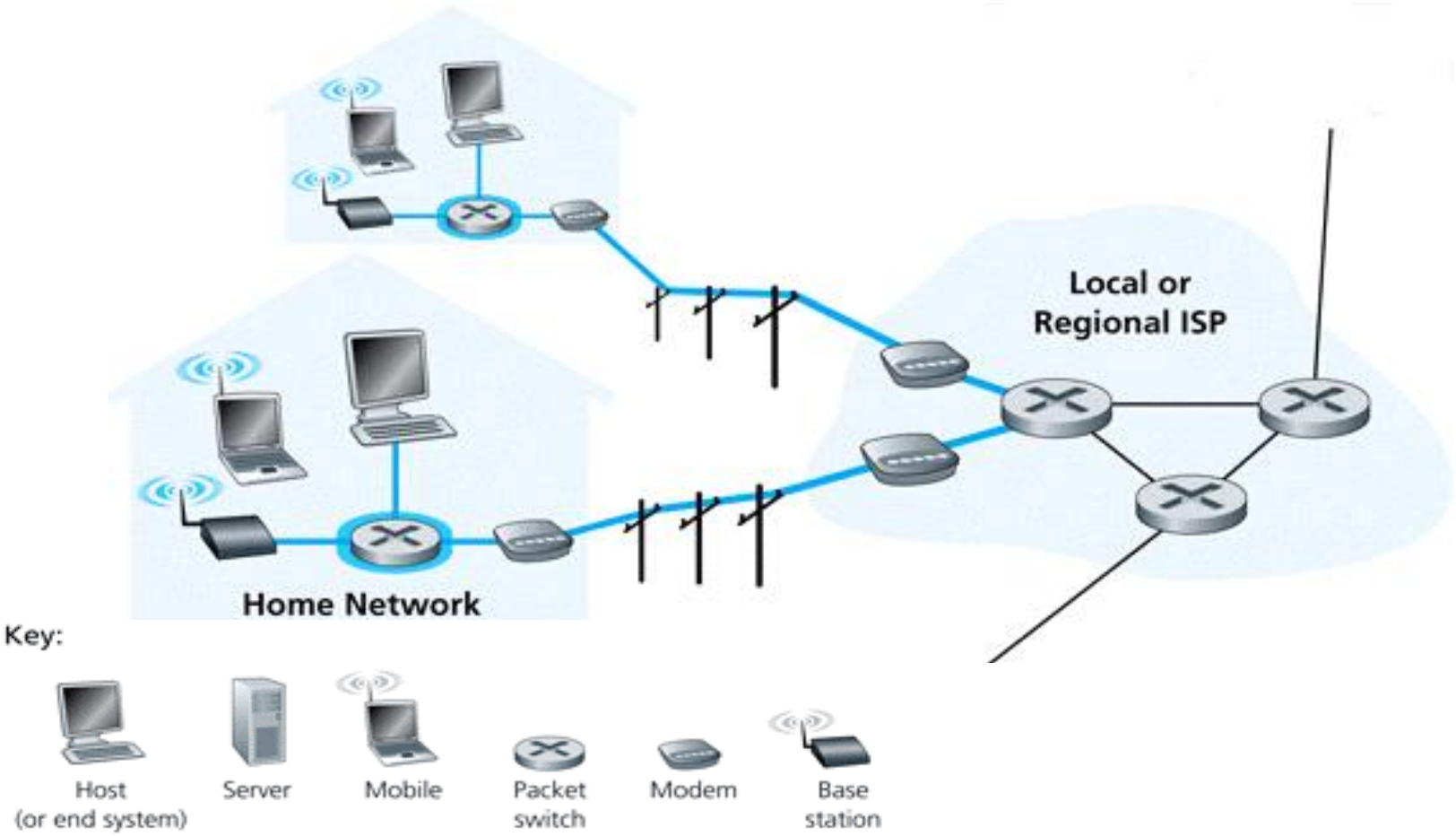
Nuts-and-Bolts Description

- Network Components
  - The Network Edge
    - End Systems (Clients, Servers, etc)
    - Example: desktops PCs, UNIX workstations, PDAs, etc
  - The Network Core
    - Intermediate nodes (Network nodes)
    - Example: Routers, Switches, Bridges, etc
  - Communication Links
    - Example: Twisted-pair copper wire, Satellite Radio Channels, Fiber optic, etc

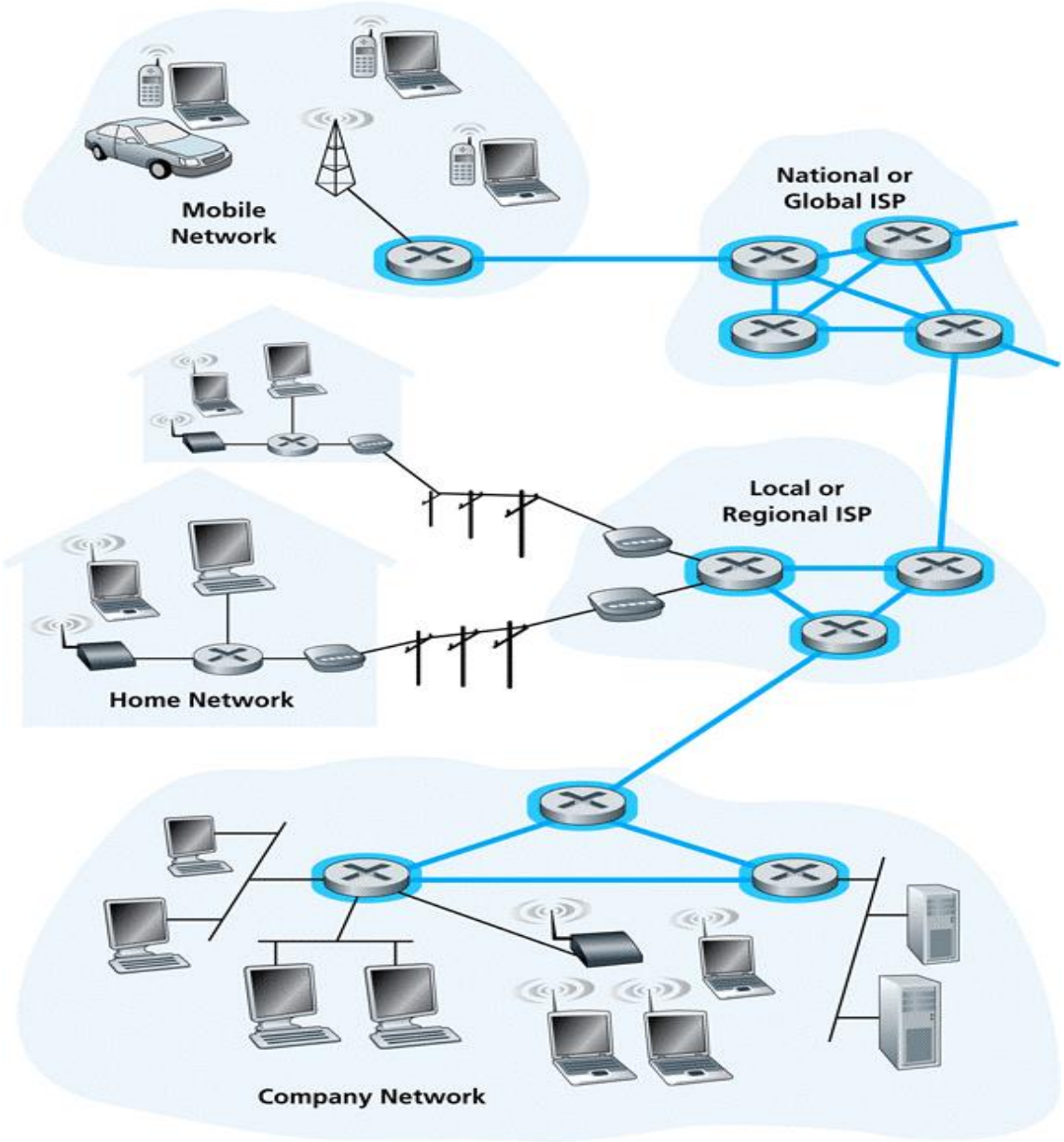
Example: A Company Network

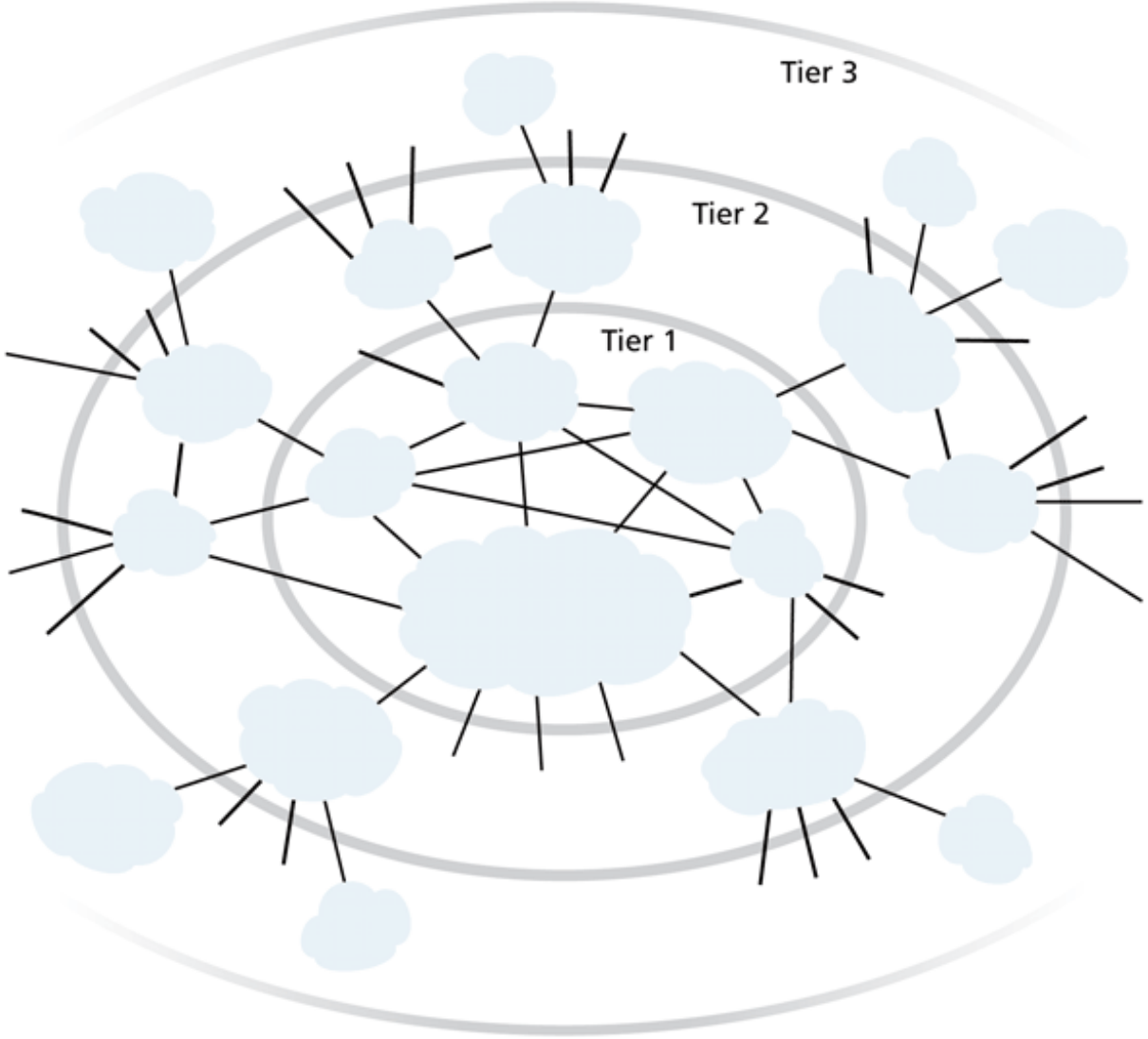


Example: A Home Network



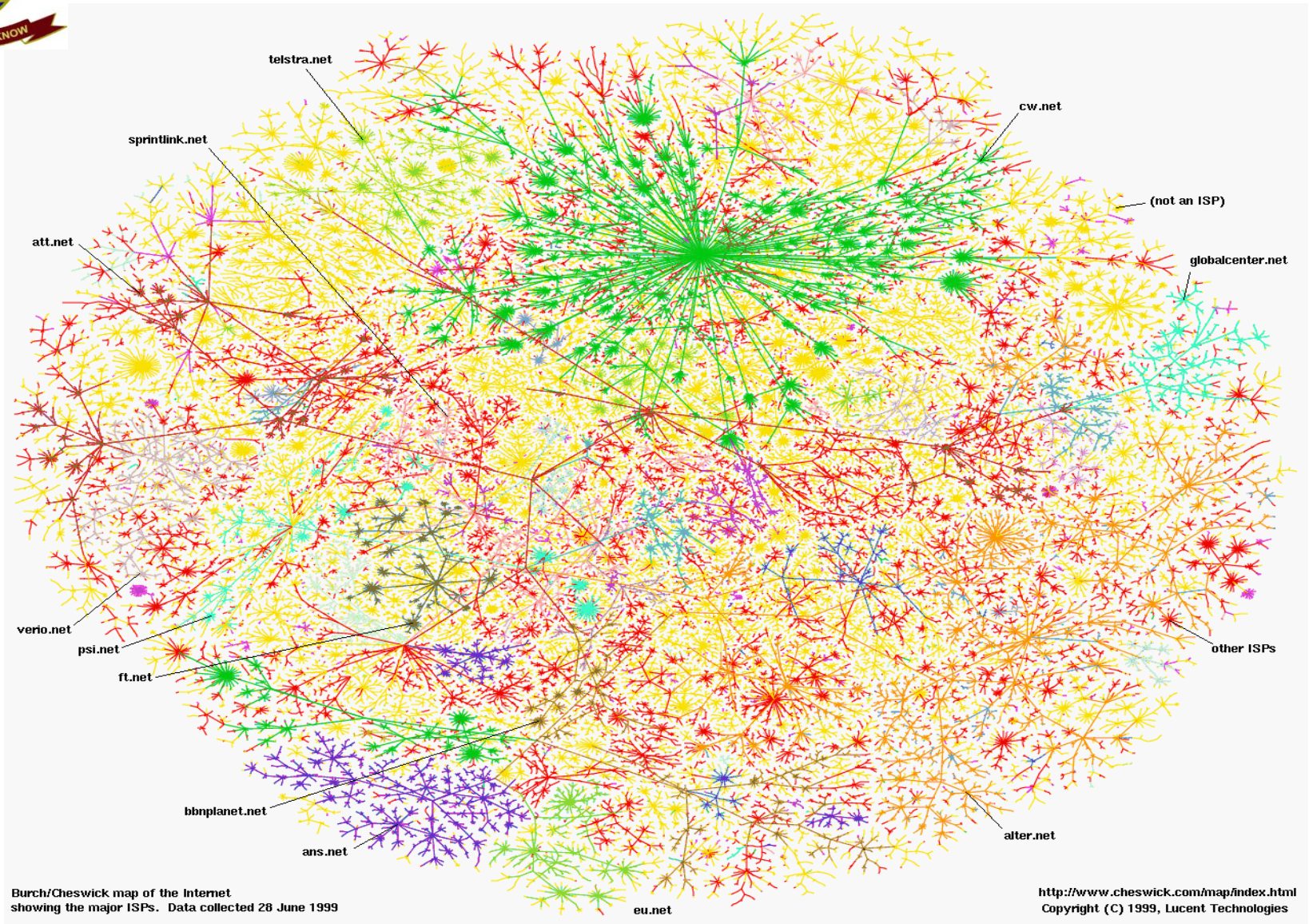
Example


Mobile
Network
National or
Global ISP
Local or
Regional ISP
Home Network
Company Network



Interconnection of ISPs

The Internet



Logical Network Architecture

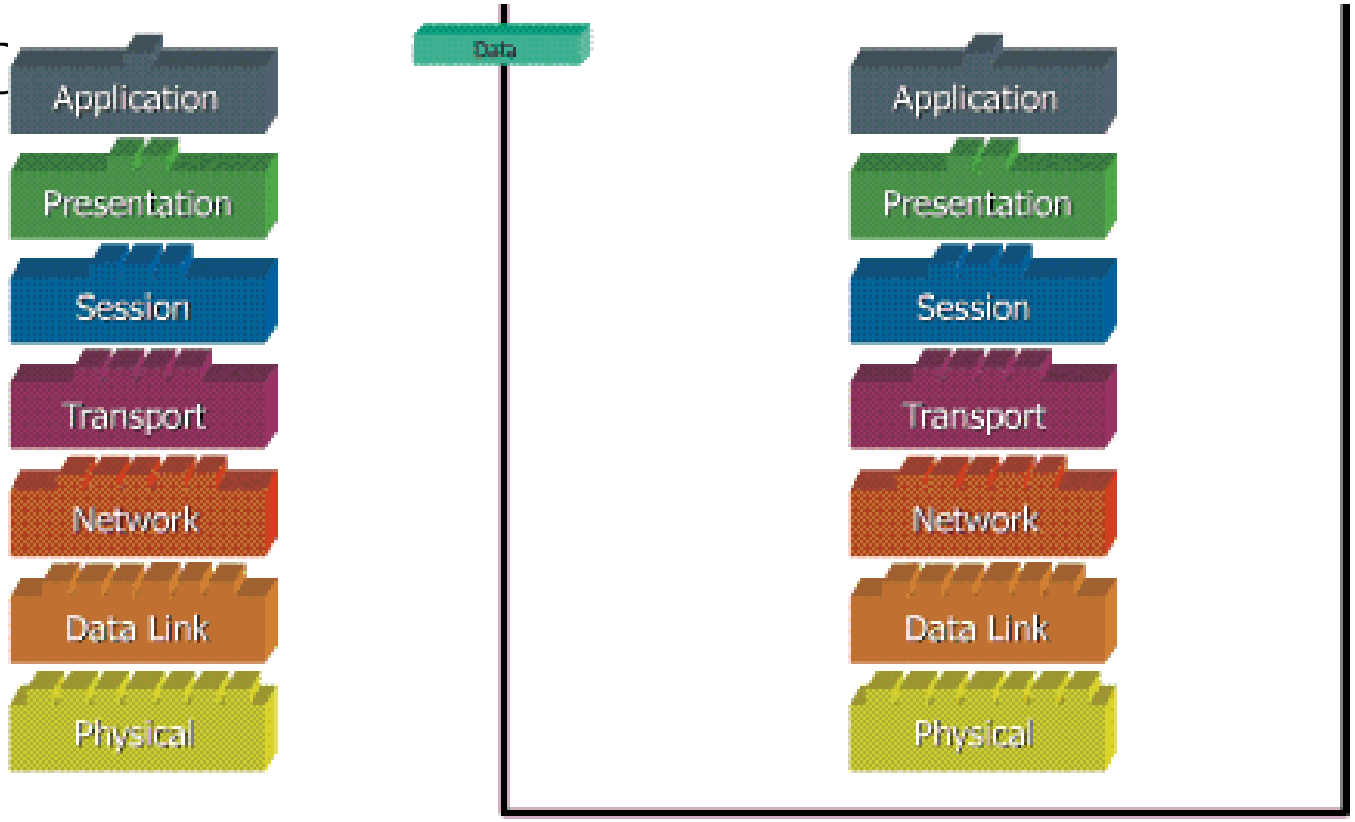
- Networking Layers
  - Divide overall set of functions into modular components.
  - Each Layer is responsible for performing particular tasks which are defined in different protocols.
- Why Layered Model?
  - **Reduces complexity** - by dividing the processes into groups, or layers, implementation of network architecture is less complex
  - **Provides compatibility** - standardized interfaces allow for "plug-and-play" compatibility and multi-vendor integration
  - **Accelerates evolution of technology** - developers focus on technology at one layer while preventing the changes from affecting another layer

OSI Model

- OSI was developed in 1984 by ISO.
- An abstract description for layered communications and computer network protocol design.

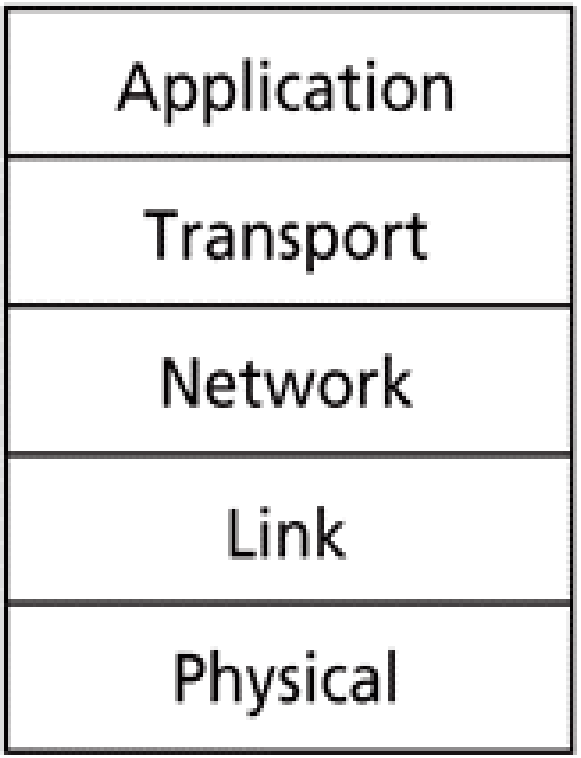
OSI Model

- I

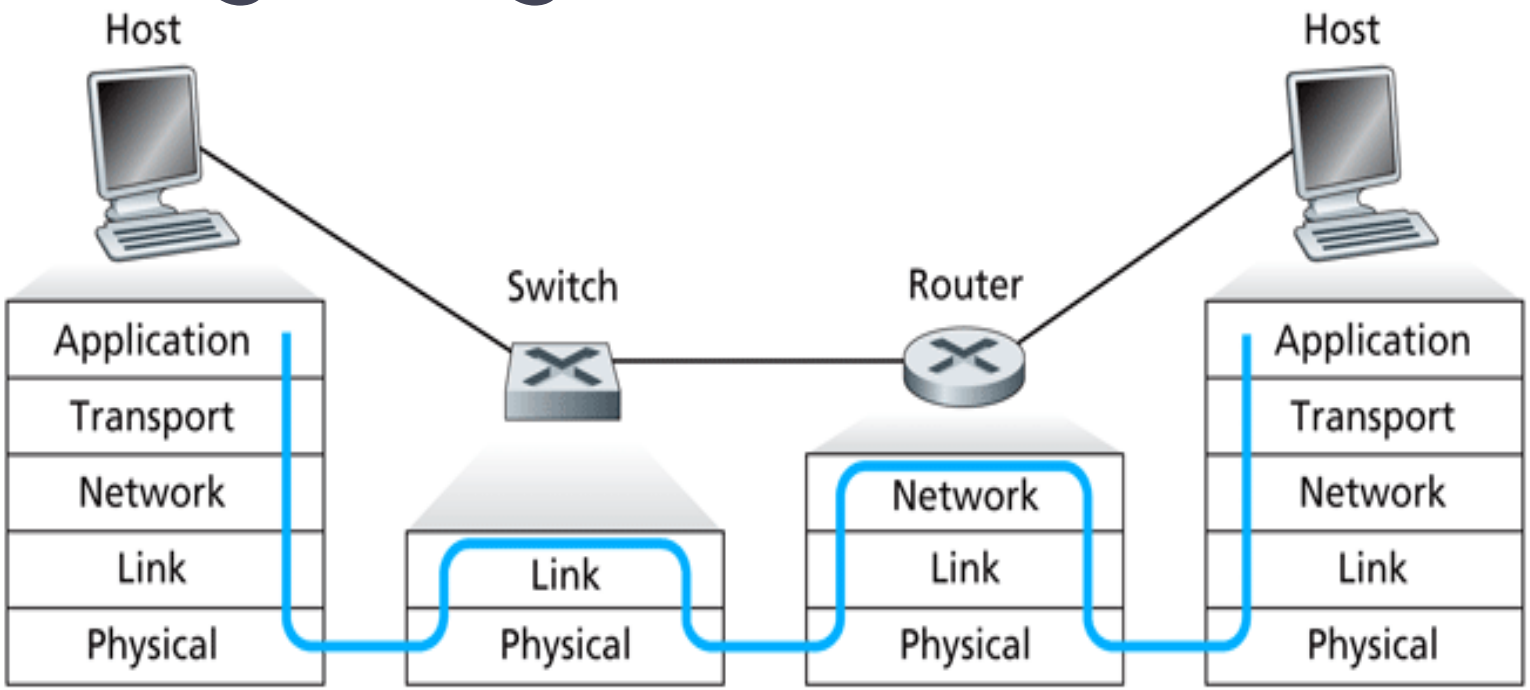

Application
Presentation
Session
Transport
Network
Data Link
Physical
Data
Application
Presentation
Session
Transport
Network
Data Link
Physical

TCP/IP Model

- Also known as Internet Protocol Stack.
- The Transmission Control Protocol/Internet Protocol (TCP/IP) suite of protocols was developed by the Defense Advanced Research Projects Agency (DARPA) in 1970s.
- Later, TCP/IP was included with the Berkeley Software Distribution of UNIX.



Putting it Together!



Summary

- The Internet is a network of networks!
- Networking functions are compartmentalized in logical layers.
- Each Layer is responsible for performing particular tasks (as well as interacting with layers above and below it) which are defined in different protocols.
- The protocols at one layer rely on and use the services of the layers below.